eWPT (penetration testing) notes

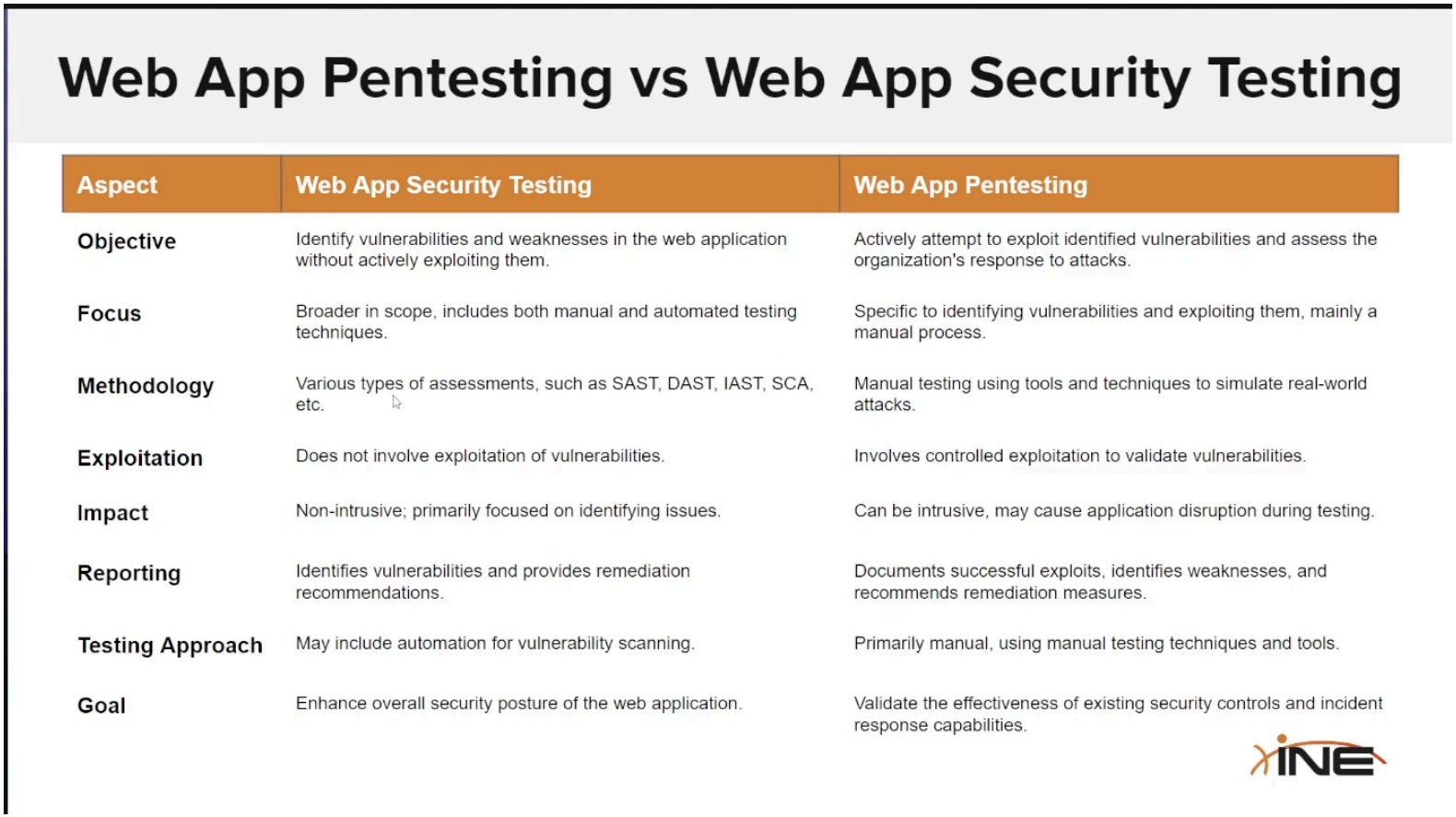
Web app security testing

- process of evaluating and assessing the security aspects of the web app to identify Vuln , weakness , potential risks
- conducting various tasks and assessments to ensure that web applications are resistant to security threats and can effectively protect data and its functions

Types of Web app security Testing

- automated scanning tools and manual testing
- Vuln scanning -> SQLi , XSS .
- Pen testing : simulating real scenario attack
- Code review and static analysis : security misconfiguration & potential security risks.
- Authentication and authorization : Evaluating the effectiveness of auth mechanisms and access control features to ensure that only authorized user have appropriated access level
- Input & Output encoding Validation :Assessing how the app handles user input to prevent (XSS & SQLi)
- Session Management Testing: verify how app manage user sessions and related tokens to prevent session attack.
- API security Testing : app program Interface Used by web applications for data exchange & Integration With other systems.

Web app pen testing is a subset of web security testing.



Web app pen testing	**Web app security Testing**
Focus on exploiting vulnerabilities	Cover a border range of assessments static and dynamic analysis
Aim to validate and assess the org ability to detect and respond to attack	Identify weaknesses
manual tech involving tools and tech to exploit	automatic and manual tech
able it in controlled and authorized manner	doesn't contain exploit

common Web app threats and risks

- Web are constantly exposed to various security threats and risks due to their wide spread accessibility and the vulnerable data
- Web app security require a pro active and comprehensive approach to mitigate and protect sensitive data and user Interactions .

Threat	Risk
a potential source of harm, event that may lead to exploit	potential for a loss or harm resulting from a threat exploiting Vuln

Common Web app Threats

XSS

- Inject malicious script into web pages leading to unauthorize access to user data , session hijacking , browser manipulation

SQLi

- inject malicious SQL code into the app data base leading to data base compromise

CSRF

- Trick authenticated users to unknowingly preforming actions on the web

Security misconfiguration

- improper configuration (severs , data base , app can expose data).

Sensitive data exposure

- Failure to protect sensitive data (passwords, Personal info)

Brute force

File upload vuln

DOS , DDOS

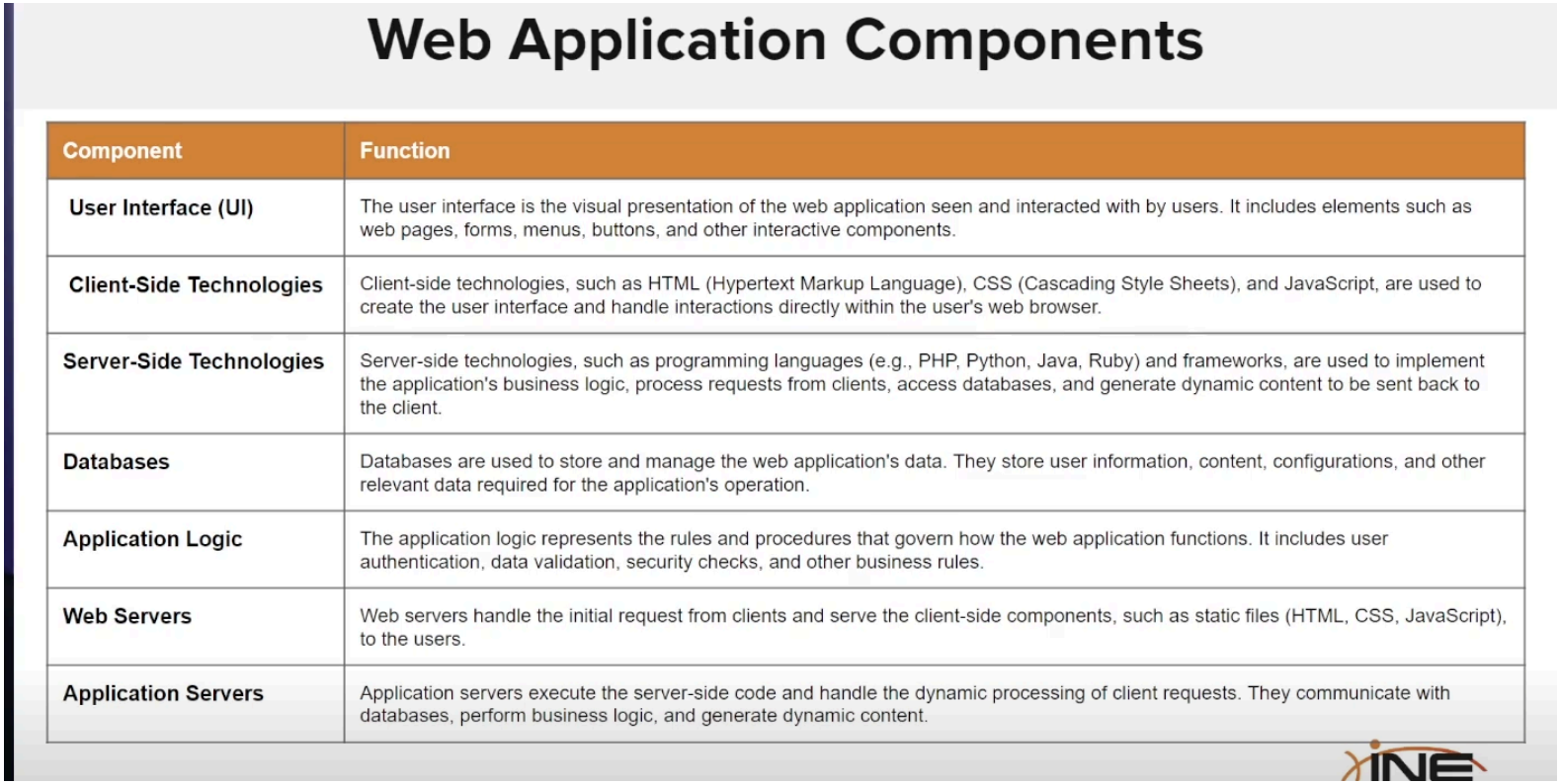
Inadequate Access Control

- Weak access controls may allow unauth users to access restricted Functions.

Broken access Control

Web app Architecture

- refers to the structure and org of components and tech to build a web app
- It defines how diff parts of app interact with each other to deliver the function ensuring (Scalability , maintainability , security)



Web Application Components

Component	Function
User Interface (UI)	The user interface is the visual presentation of the web application seen and interacted with by users. It includes elements such as web pages, forms, menus, buttons, and other interactive components.
Client-Side Technologies	Client-side technologies, such as HTML (Hypertext Markup Language), CSS (Cascading Style Sheets), and JavaScript, are used to create the user interface and handle interactions directly within the user's web browser.
Server-Side Technologies	Server-side technologies, such as programming languages (e.g., PHP, Python, Java, Ruby) and frameworks, are used to implement the application's business logic, process requests from clients, access databases, and generate dynamic content to be sent back to the client.
Databases	Databases are used to store and manage the web application's data. They store user information, content, configurations, and other relevant data required for the application's operation.
Application Logic	The application logic represents the rules and procedures that govern how the web application functions. It includes user authentication, data validation, security checks, and other business rules.
Web Servers	Web servers handle the initial request from clients and serve the client-side components, such as static files (HTML, CSS, JavaScript), to the users.
Application Servers	Application servers execute the server-side code and handle the dynamic processing of client requests. They communicate with databases, perform business logic, and generate dynamic content.

client-side model	Server -side model
Interface (Front end) responsible for displaying the web page and handle user input and sending requests	(back end) process client requests execute app logic , communicate with data base and other services , generate response
UI , Responsive User Experience, Java script , Data validation ,	Data Processing , Security , server side language , data storage

Server side tech

- web server receiving and responding to HTTP requests from the client.
- It hosts web app Files , processes requests and send the response

- APP server -> Manage the business logic of the web app . process user requests accessing database and preform computation to generate dynamic content
- Data base server -> store and manage data base of web app
- Server side script -> (Java , PHP , Python , Ruby)

OWASP TOP 10

- A01 Broken Access Control
- A02 Cryptographic failure
- A03 Injections (XSS , SQLi)
- A04 Insecure design
- A05 Security misconfigurations
- A06 Vulnerable and outdated components
- A07 Identification and Authentication Failure
- A08 Software and data Integrity failure
- A09 Security logging and monitoring Failure
- A10 Server side Request Forgery (SSRF)

OWASP web security Testing Guide (WSTG)

- is a comprehensive and community resource
- to conduct effective web app security assessments by testing web app for security vuln
- it serves as a practical and hand-on reference for planning , executing and reporting on web app security testing.

WSTG

- help to track the status of completed and pending test cases
- include a comprehensive pen testing methodology
- Framework the web app can implement in their pen tests and security assessments .
- set of detailed and granular web app security tests that outline the various tech that test most of common web mis configurations.

Phases

Pre Engagement phase

- lays the foundation for a successful and well planned security assessment
- understand the project requirements
- agree on some tech details

main section

- Objectives and scope of the Engagement
- Timeline and milestone
- liabilities and responsibilities
- Expectations and deliverables
- Statement of work

Pre Engagement steps

- Understand objective and goals
- Scope Definition
- Authorization and legal Req
- Rules of engagements
- communication and coordination
- contract and non disclosure agreements
- Scoping meeting
- preparation of tools and resources
- Risk assessments and acceptance
- Engagements Kick-off

Documentation and communication Findings

- the report phase in web -> document and communicate Findings
- report must be detailed document that provide valuable info to the stakeholders , including developers , managers , and IT teams about the security posture
- must be well structured and concise report is essential for enabling informed decision-making.
- communicating the Finding to diff audience to get the info related to all teams
- must be aware of each vuln and its criticality your report will depend on BC (business continuity) of the org the report must be comprehensive as possible with regard of the scope.

Writing Report

- no standardized structure for that
- but there are best practice

Documentation of your findings

- collect and organize information
- simply gather and present this info in readable and professional format
- Mind mapping tools and spread sheets
- structure and relationships

Google dorks

- Google Dorks this is used to get target domains , subdomains , PDF files , Files

```
type this in url
site:website # to limit domain search
INURL: admin # to find admin
         : forum # to find forum
site:*ine.com # to show subdomains , same as sublist3r
Intitle:admin # limit all the results to subdomains with admin
Site:employees # to find Indviduals and employees
Intitle:empolyees
```

```
cahce:website # to find older version
INURL:auth_user_File.txt # any pass that has leaked
```

in older versions of a website you may find an important information . Google Hacking database

DNS Recon

First we net to find records of a domain

- tools DNS Recon DNSrecon → is a python script that provide the ability to preform check all DNS records for zone transfer , enumerate general DNS records for a given domain.

```
$Dnsrecon -d website # to get domain name , name server
```

  - Types of records you may see
    - A record → IPv4
    - AAAA record → IPv6
    - MX record → Mail server address
    - TXT record → text record to track website analytics

  another tool DNS Dumpster → identify sub domains & domains same as DNSrecon
- 🐶WAF detection using wafwoof tool → it detect a number of firewalls & proxy & web app firewall

```
$wafwoof -a IP # for finding all
```

- Subdomain Enumeration using Sublist3r sublist3r is a passive technique sublist3r → python tool designed to enumerate subdomains of websites using ONIST to collect and gather subdomains from the target *#note* use VPN if engine blocks the enumeration Request

Copying website with HTTPRACK

- Copying website to your local system to do analysis

```
sudo apt-get httprack
httprack URL
```

- passive tech downloads all the web site